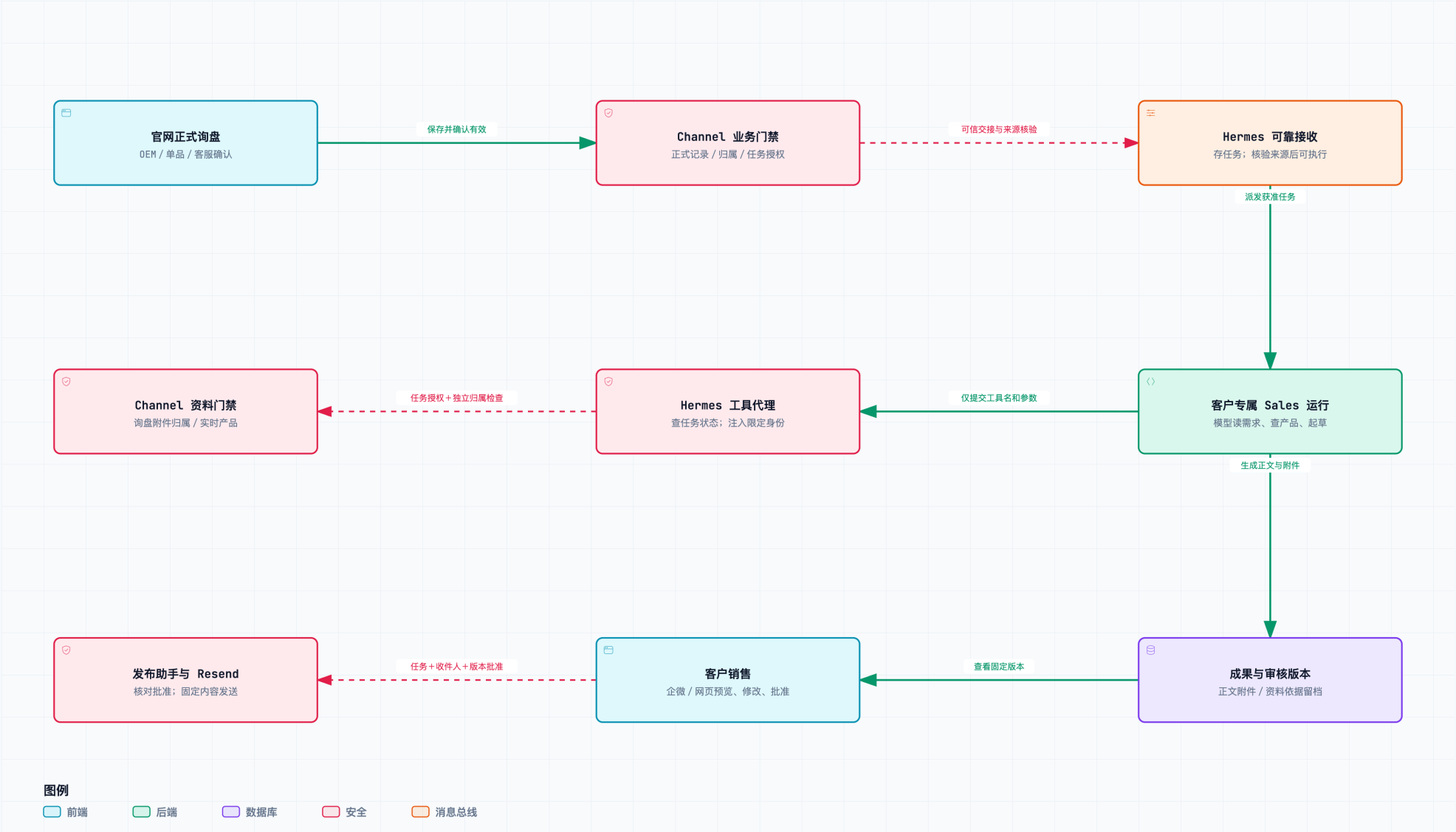
Sales 权限：系统把关，模型负责准备

推荐：Hermes 执行通用任务权限，Channel 独立核对业务资料；使用现有服务凭据加短时任务读取授权。生成模型不持有密钥，也没有数据库、对象存储或发送入口。

负责方	负责什么	当前主要缺口
Hermes 通用后端	认证客户与服务；任务、run、动作、暂停、接管、审批及发送状态	补任务级授权、来源核验和真实工具接线
Channel 业务后端	确认正式提交；检查记录、附件、产品资料的归属与允许范围	补任务读取授权；收紧历史记录归属条件
模型与内容工厂	理解需求、查获准产品、生成正文附件、说明缺项	接入有限工具循环；不能判断权限是否有效
客户销售与发布助手	销售查看、修改、批准；发布助手复核固定版本后发送	企微／网页共用审批后端；唯一发送账仍待实现

已有连接、客户目录与可靠队列可复用。现有隔离测试不等于任务授权和线上闭环已经完成。

官网询盘：来源、读取、审核与发送



这是目标流程。Channel 保存正式询盘后自动交接，来源核验通过才执行。产品准备查最新批准资料；实质邮件经人工批准。固定确认信为独立预批准分支，只发一次。

任务授权：拿到客户密钥仍不能随便读

用一个例子说明

A 公司有询盘 101 和 102。处理 101 的任务只能读 101 及其获准附件；即使 102 也属于 A，当前任务也不能直接读。为推荐产品，可以读取 A 当前业务允许的其他 SKU，但不开放内部底价和其他客户资料。

步骤	系统完成的检查
1. Channel 最终提交	保存来源交接记录，确认询盘、附件最终有效；模型说“已提交”无效
2. Hermes 持久接收	事务保存事件、任务和待派发记录；202 只表示受理，不表示已生成邮件
3. 两端登记读取范围	认证连接；Channel 核验来源，为确定的 task/run 登记短时读取授权
4. 每次真实读取	Hermes 核对当前任务；Channel 独立查授权、资料归属，并在线核对任务许可
5. 返回前再核对	撤权、任务变化或服务暂不可用即拒绝；代理丢弃晚到旧结果

授权句柄和服务凭据只留服务器。建议 5 分钟有效期并可续期；暂停主要依靠当前任务状态检查，不能只等授权自然过期。已返回的数据无法收回，暂停必须显示在途请求边界。

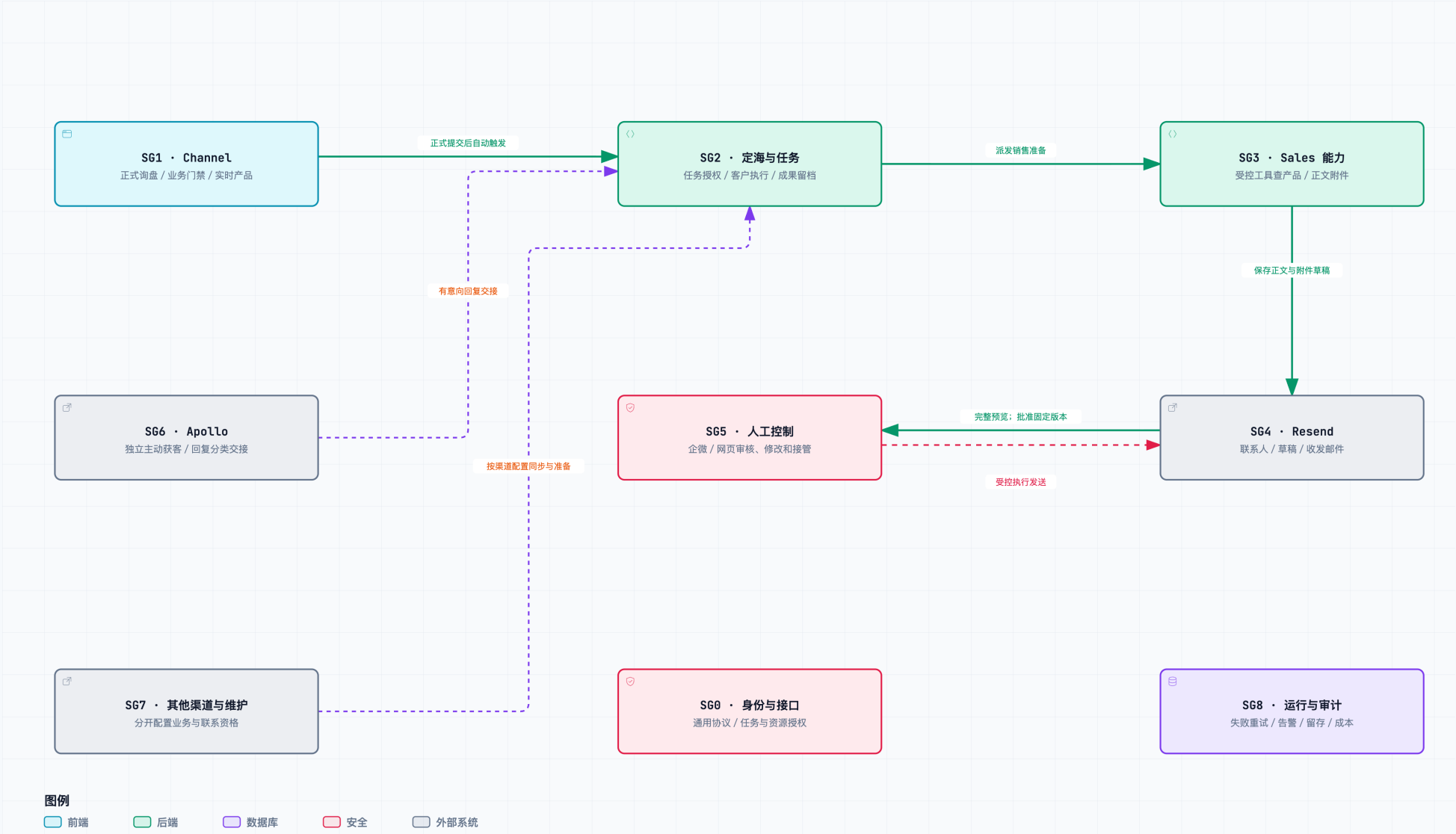
产品与记忆：用新资料，保留当时依据

时点／范围	采用规则
买家提交	保留原始需求、选择、时间和已有单品快照；后续产品变化不能覆盖它
Sales 准备	每次通过获准 API 查询当前批准产品；缺价格、交期等就标缺项，不凭模型补数
人工审核／发送	固定正文、收件人、附件及实际采用的字段和版本；相关商务依据变化重新审核
任务私有上下文	HOME、原始邮件、询盘附件和续办记录按任务恢复，不加载整个客户的历史记忆
客户共享知识	只共享本业务批准的产品、品牌与写作规则；索引、缓存和日志也遵守客户与资源范围

已有客户 HOME 挂载只能说明客户边界；若它装有其他询盘，就需要收紧为任务范围。这是本轮明确要改的地方。

实时查询不等于实时库存或自动锁价。审核需要保留实际引用内容，只存 hash 无法复盘。外部资料查询与发送不能组成原子事务，本期不提供报价有效期或库存预留保证。

共用底座，获客、询盘与维护分别配置



沿用定海调度、内容工厂、发布助手、邮件工具与人工入口。官网询盘独立自动触发，不必等销售下令；Apollo 仍是主动获客流程。客户级连接与任务级权限贯穿各业务。

哪些能复用，确认后先补什么

已有基础	保留	需要补齐
SG0 合同与连接	双语言校验、固定身份、动作授权、fresh registry	认证信封、任务／run／资源授权；schema 本身不授予权限
SG1 Channel 资料接口	询盘投影、批准产品 reader、附件 bytes／hash／Range	来源完成证明、安装归属、任务 lease 与每资源门禁
SG2 客户运行与接收	目录 owner、容器限制、MySQL事务、原 Dispatcher	来源等待核验、任务私有HOME、当前任务检查、实际模型与HTTP工具接线

建议确认的四项

① 两端门禁 + 短时任务授权；② 单客户 Sales 服务／数据库凭据，归属不明旧数据拒绝；③ 私有上下文按任务隔离，共享知识限获准业务资料；④ 产品实时查询，提交事实和审核依据留档。

确认后顺序：共同协议 → Channel 来源与资料门禁 → Hermes 核验与任务控制 → 真实工具和成果 → 草稿、审批及唯一发送。逐项完成开发、复核和验证；本轮没有实施这些改动。

必须验证：A/B 客户、同客户双任务、过期与撤销、暂停竞争、伪造来源、恶意模型、真实容器／数据库权限及重复发送。宿主机／云账号整体失陷需更高隔离等级，不能由这些门禁承诺绝对安全。

完整设计：docs/sales-agent/SECURITY-AND-TOOLS-DESIGN.md。代码核对：Channel 33e9f504，Hermes 2fbc50c。参考 OWASP Authorization、Multi-Tenant Security、AI Agent Security；本 PDF 是项目设计摘要，非安全认证。